

SecureForge Web

Relatório de Postura de Segurança

Gerado em 24/07/2026, 16:48:38

Identificação da aplicação

OWASP NodeGoat

Stack: Node.js e MongoDB

Análise: Análise 24/07/2026 — Checklist Essential SecureForge v1.0

Concluída em: 24/07/2026

Gerado por: SecureForge Web (secureforgeweb@gmail.com)

Resumo executivo

33%

Score de postura

16

Total de achados

16

Achados abertos

0%

Taxa de resolução

Achados por severidade

Crítica: 4

Alta: 8

Média: 3

Baixa: 1

Plano de ação priorizado

AUTHZ-03 — Rotas administrativas protegidas

Crítica · Imediata · Aberto · Autorização

Ação recomendada: Exija autenticação + autorização admin em todas as rotas /admin.

INPUT-02 — Queries SQL parametrizadas

Crítica · Imediata · Aberto · Validação de entrada

Ação recomendada: Use ORM ou prepared statements; nunca concatene SQL com input do usuário.

SECRET-02 — Ausência de credenciais no repositório

Crítica · Imediata · Aberto · Proteção de credenciais

Ação recomendada: Execute varredura de segredos e rotacione credenciais expostas.

DATA-01 — HTTPS/TLS em trânsito

Crítica · Imediata · Aberto · Dados sensíveis

Ação recomendada: Configure TLS em todos os ambientes acessíveis externamente.

AUTH-01 — Política de senha mínima

Alta · Curto prazo · Aberto · Autenticação

Ação recomendada: Exigir 8+ caracteres com maiúscula, minúscula, número e especial.

AUTH-03 — Proteção contra força bruta

Alta · Curto prazo · Aberto · Autenticação

Ação recomendada: Implemente rate limit no endpoint de login e bloqueio temporário.

AUTHZ-01 — Controle de acesso por perfil

Alta · Curto prazo · Aberto · Autorização

Ação recomendada: Mapeie papéis e aplique verificação em todas as rotas sensíveis.

AUTHZ-02 — Princípio do menor privilégio

Alta · Curto prazo · Aberto · Autorização

Ação recomendada: Audite papéis e remova acessos desnecessários.

INPUT-01 — Validação server-side

Alta · Curto prazo · Aberto · Validação de entrada

Ação recomendada: Implemente validação com schema (Joi/Zod) em todos os endpoints.

HEADER-01 — Content-Security-Policy

Alta · Curto prazo · Aberto · Headers de segurança

Ação recomendada: Defina Content-Security-Policy adequada ao tipo de aplicação.

HEADER-02 — Strict-Transport-Security

Alta · Curto prazo · Aberto · Headers de segurança

Ação recomendada: Configure Strict-Transport-Security em produção.

DATA-02 — Dados sensíveis fora de logs

Alta · Curto prazo · Aberto · Dados sensíveis

Ação recomendada: Mascare dados sensíveis antes de registrar em logs.

HEADER-03 — X-Frame-Options / frame-ancestors

Média · Médio prazo · Aberto · Headers de segurança

Ação recomendada: Use X-Frame-Options: DENY ou CSP frame-ancestors.

HEADER-04 — X-Content-Type-Options

Média · Médio prazo · Aberto · Headers de segurança

Ação recomendada: Defina X-Content-Type-Options: nosniff.

SURF-02 — Dependências atualizadas

Média · Médio prazo · Aberto · Superfície de ataque

Ação recomendada: Execute auditoria (npm audit) e atualize pacotes com CVEs críticos.

ERROR-02 — Mensagens genéricas ao usuário

Baixa · Baixa · Aberto · Mensagens de erro

Ação recomendada: Use mensagens uniformes para falhas de autenticação e validação.

